

Guides de sécurité pour les utilisateurs

Guide 1 : Appel à la vigilance

1. **Pause 10s et réflexion** : réfléchir avant de cliquer.

Règles: 1) relis ; 2) vérifie ; 3) demande un avis.



2. **Ne céder pas à l'urgence = soupçon** : les arnaques pressent.

Règles: 1) pas de panique ; 2) contrôle par téléphone ; 3) trace l'échange.



URGENCE = SUSPICION

Réfléchis avant de cliquer !



3. **Si demande de l'argent = double vérif** : paiements sous validation.

Règles: 1) procédure ; 2) deux personnes ; 3) canal indépendant.



NE PAS CÉDER AUX DEMANDES D'ARGENT

Vérifiez toujours la source avant d'agir.
En cas de doute, contactez votre
service informatique ou votre hiérarchie.

4. **Doute = ne pas faire** : l'inaction vaut mieux qu'un clic.

Règles: 1) stop ; 2) escalade ; 3) attendre consignes.



DOUTE NE PAS FAIRE

**Un doute ?
Demandez avant d'agir.**

5. **Confidentialité en public** : pas de sujets sensibles.

Règles: 1) voix basse ; 2) orientez votre écran ; 3) pas de photos.

CONFIDENTIALITÉ EN PUBLIC



 Parlez à voix basse

 Orientez votre écran



 Parlez à voix basse.

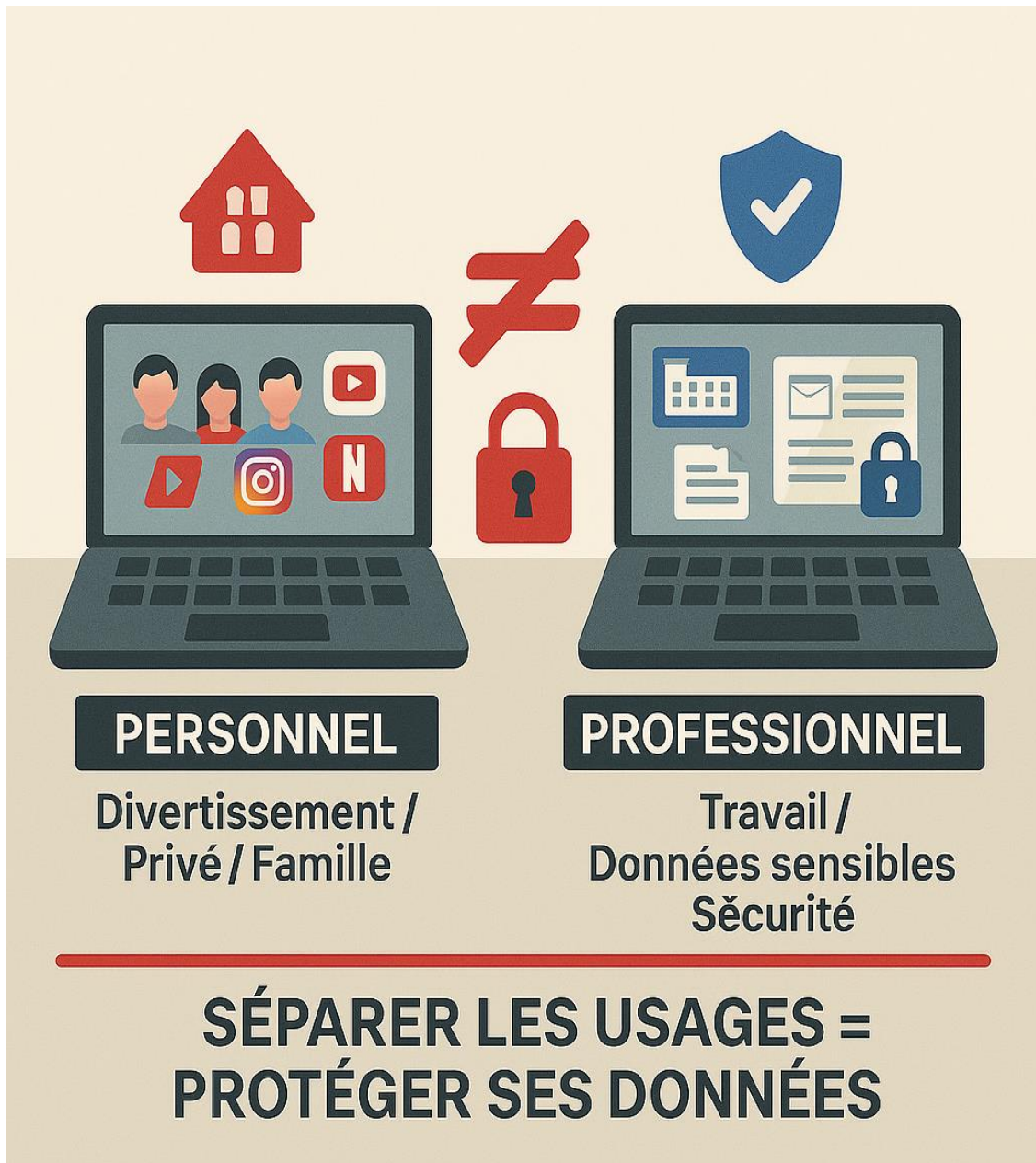
 Orientez votre écran.

 Pas de photos, même discrètes.

CYBERSÉCURITÉ – BONNES PRATIQUES

6. **Séparer pro/perso** : éviter les mélanges.

Règles: 1) comptes dédiés ; 2) pas de cloud perso ; 3) navigateur séparé.



7. **Téléchargements sûrs** : sources officielles seulement.

Règles: 1) site éditeur ; 2) pas de cracks ; 3) scanner.



8. **Partages temporaires** : liens avec date d'expiration.

Règles: 1) droits minimaux ; 2) durée courte ; 3) révoquer après usage.



PARTAGES DE FICHIERS SÉCURISÉS ET LIMITÉS DANS LE TEMPS

Liens chiffrés, accès temporaires,
sécurité garantie.

9. **Badges et bureaux** : ne facilite pas les accès, pas d'accès opportuniste.

Règles: 1) clean desk ; 2) badge perso ; 3) ne fais pas "suivre".



POSTE VERROUILLÉ = DONNÉES PROTÉGÉES

**Mot de passe, badge, authentification:
sécurité assurée**

10. **QR prudents** : QR = lien non fiable.

Règles: 1) vérifie support ; 2) tape l'URL ; 3) refuser d'installer.



Guide 2 : Défense numérique

1. **Phishing = hameçonnage = lien piégé.**

Règles: 1) vérifier l'expéditeur ; 2) lire l'adresse complète ; 3) ne pas cliquer.



2. **Faux mail = vrai danger.**

Règles: 1) orthographe suspecte ; 2) ton alarmiste ; 3) lien douteux = poubelle.



3. **Mots de passe forts = barrière essentielle.**

Règles: 1) minimum 8 caractères ; 2) lettres + chiffres + symboles ; 3) jamais identique partout.



MOT DE PASSE FORT =

**Alphabétiques et numériques
et SPECIALES**

> 8 CARACTÈRES

4. **Phrases de passe = sécurité et mémoire.**

Règles: 1) une phrase unique ; 2) facile à retenir ; 3) difficile à deviner.

(Exemple : "J'aimeLesGâteaux!2025")

PHRASES DE PASSE = SÉCURITÉ + MÉMOIRE



Règles:

- 1** Une phrase unique
- 2** Facile à retenir
- ✓ Difficile à deviner

Exemple : J'aimeLesGâteaux!2025

**** Ne pas réutiliser**

5. **MFA / Double vérification : bouclier supplémentaire.**

Règles: 1) activez-la ; 2) ne partagez pas le code ; 3) ne validez jamais à l'aveugle.

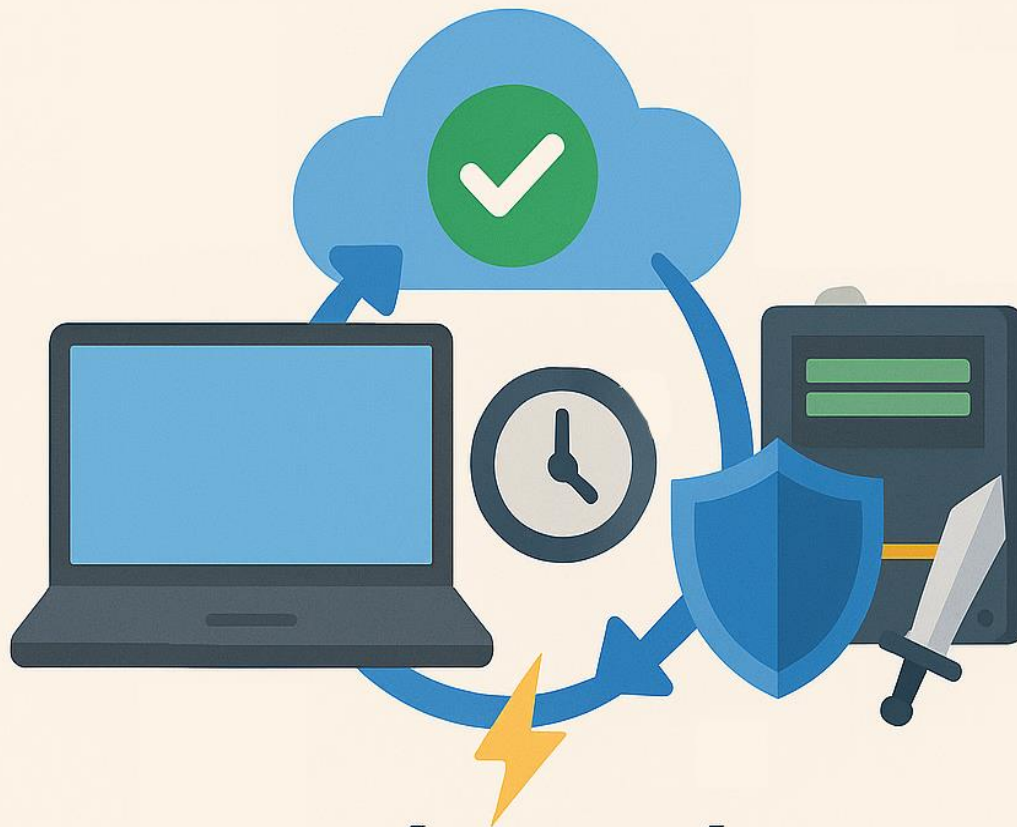


6. **Mises à jour = protection et performance.**
Règles: 1) système ; 2) logiciels ; 3) antivirus.



7. **Sauvegarde régulière = sérénité garantie.**

Règles: 1) sauvegarde automatique ; 2) sur disque externe ou cloud pro ; 3) test de restauration.



**SÉCURITÉ =
SAUVEGARDES +
TESTS DE RESTAURATION**

Cloud + Support externe = Double sécurité

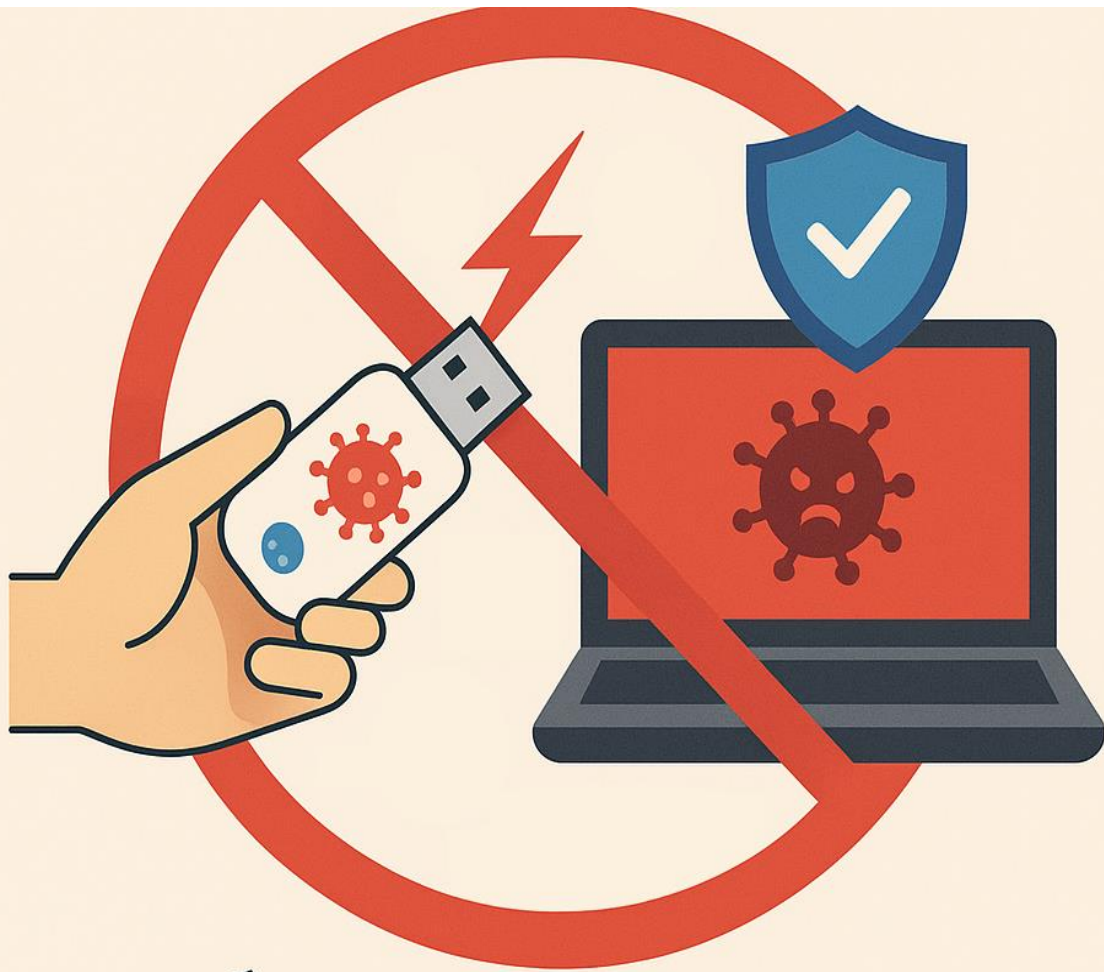
8. **VPN activé = Wi-Fi public sécurisé.**

Règles: 1) activez-le en dehors du bureau ; 2) évitez les Wi-Fi ouverts ; 3) désactivez-le en local.



9. **Clé USB inconnue = virus assuré.**

Règles: 1) ne branchez jamais sans vérif ; 2) analyse antivirus ; 3) privilégier le cloud.



CLÉ USB INCONNUE = VIRUS PROPAGÉS

Ne branchez jamais
un périphérique non identifié

10. Alerter vite = protéger les autres.

Règles: 1) prévenir le service IT ; 2) noter les détails ; 3) ne pas supprimer les preuves.



Guide 3 : Culture Cyber Quotidienne

1. **Objets connectés (IOT) piratables = attention botnet.**

Règles: 1) mot de passe unique ; 2) mises à jour ; 3) débranchez quand inutile.

2. **Phishing / Malware / Ransomware = attaque.**

Règles: 1) ne cliquez pas ; 2) débranchez le réseau ; 3) contactez l'assistance.

3. **Réseaux sociaux = exposition maîtrisée.**

Règles: 1) pas d'infos sensibles ; 2) comptes privés ; 3) vigilance sur les photos.

4. **Téléphone = mini-ordinateur.**

Règles: 1) code fort ; 2) applications officielles ; 3) Bluetooth désactivé.

5. **Écran verrouillé = données protégées.**

Règles: 1) mot de passe ou empreinte ; 2) verrouillage automatique ; 3) jamais ouvert sans surveillance.

6. **Mot de passe prêté = risque partagé.**

Règles: 1) compte personnel = usage personnel ; 2) ne jamais transmettre ; 3) réinitialiser si doute.

7. **Emails automatiques = prudence accrue.**

Règles: 1) évitez les liens ; 2) passez par le site officiel ; 3) vérifiez le domaine.

8. **Appareils personnels = responsabilité personnelle.**

Règles: 1) antivirus installé ; 2) système à jour ; 3) usage limité.

9. **Conversation numérique = prudence verbale.**

Règles: 1) pas de secrets par chat ; 2) ton professionnel ; 3) effacez après usage.

10. **Humain = premier pare-feu.**

Règles: 1) restez curieux ; 2) posez des questions ; 3) formez-vous régulièrement.

Attaques

Définitions des attaques les plus utilisées :

01. **Phishing** : Message trompeur (mail/SMS) visant à voler des identifiants.
02. **Réutilisation d'identifiants** : Tests automatisés d'identifiants volés sur plusieurs services.
03. **Spam** : Courriels massifs indésirables, parfois porteurs d'arnaques.
04. **Malware (trojan / backdoor)** : Programme malveillant installé pour voler ou contrôler un système.
05. **Ransomware** : Logiciel qui chiffre des fichiers et demande une rançon.
06. **Pièces jointes malveillantes** : Document Word/Excel qui exécute un code malveillant via macros.
07. **Business Email Compromise** : Faux e-mail de la direction pour obtenir actions financières.
08. **Clé USB piégée (USB drop)** : Clé laissée pour être branchée et infecter un poste.
09. **Rogue Wi-Fi (point d'accès pirate)** : Point d'accès frauduleux qui intercepte ou modifie le trafic.
10. **QR-code frauduleux** : QR qui redirige vers site malveillant ou lance une action dangereuse.

Guide 4 : Liste des actions pour éviter les attaques pirates :

1. **Vérifier expéditeur et lien** : contrôler l'adresse et l'URL avant d'agir.
Règles: 1) survole le lien ; 2) vérifie le domaine ; 3) si doute, n'ouvre pas.
2. **Mots de passe uniques** : un mot de passe différent par service.
Règles: 1) gestionnaire ; 2) >12 caractères ; 3) pas de partage.
3. **MFA partout** : seconde preuve à la connexion.
Règles: 1) appli d'authentification ; 2) désactive SMS si possible ; 3) codes de secours.
4. **Mises à jour automatiques** : OS et applis toujours à jour.
Règles: 1) auto-update ; 2) redémarre ; 3) évite versions obsolètes.
5. **Pièces jointes prudentes** : n'ouvre pas les PJ inattendues.
Règles: 1) vérifie l'expéditeur ; 2) pas de macros ; 3) scanne avant.
6. **Sauvegardes testées** : copies régulières, restaurables.
Règles: 1) auto ; 2) hors-ligne/immuables ; 3) test mensuel.
7. **Verrouiller l'écran** : bloquer l'accès physique.
Règles: 1) Win+L / Ctrl+Cmd+Q ; 2) temporisation courte ; 3) badge hors de vue.
8. **VPN sur Wi-Fi public** : chiffrer le trafic hors du réseau pro.
Règles: 1) VPN avant de travailler ; 2) évite portails douteux ; 3) oublie les Wi-Fi inconnus.
9. **Aucun périphérique inconnu** : ne branche pas clé/câble trouvé.
Règles: 1) remets à l'IT ; 2) autorun désactivé ; 3) matériel approuvé uniquement.
10. **Signaler vite** : alerter dès le moindre doute.
Règles: 1) contacte support ; 2) garde preuves ; 3) n'éteins pas sans consigne.

Guide 5 : Liste des règles de sécurité contre les attaques :

1. Phishing (hameçonnage)

- **Définition** : mail ou message trompeur pour voler des identifiants.
- **Règles** : vérifier l'expéditeur ; ne pas cliquer sur liens ; activer la MFA.

2. Credential stuffing / réutilisation de mot de passe

- **Définition**: essais automatisés avec identifiants volés.
- **Règles**: mot de passe unique ; gestionnaire de mots de passe ; MFA.

3. Malware (cheval de Troie / backdoor)

- **Définition**: logiciel malveillant installé sur la machine.
- **Règles**: antivirus/EDR; n'exécute pas de fichiers inconnus ; mises à jour régulière.

4. Ransomware

- **Définition**: chiffrement des fichiers et demande de rançon.
- **Règles**: sauvegardes immuables ; segmenter le réseau ; bloquer macros.

5. Business Email Compromise (BEC)

- **Définition**: usurpation d'un e-mail pour obtenir un virement.
- **Règles**: vérification multicanal pour virements ; plusieurs signatures ; DLP sur e-mail.

6. Pièces jointes malveillantes / macros

- **Définition**: document Office qui exécute du code quand on active la macro.
- **Règles**: ne pas activer les macros ; Protected View ; sandboxing des pièces jointes.

7. Attaque de la chaîne d'approvisionnement (supply-chain)

- **Définition**: compromission via un fournisseur ou un logiciel tiers.
- **Règles**: valider fournisseurs ; tests en préprod ; signatures et contrôle d'intégrité.

8. Menace interne (insider)

- **Définition**: fuite ou sabotage par un employé.
- **Règles**: DLP et logs ; revoir droits d'accès ; procédure d'offboarding stricte.

9. Brute force / password spraying

- **Définition**: essais massifs pour deviner un mot de passe.
- **Règles**: verrouillage après tentatives ; mots de passe robustes ; surveillance SIEM.

10. Injection SQL

- **Définition**: envoi de commandes SQL malveillantes via une entrée web.
- **Règles**: requêtes paramétrées ; validation d'entrée ; WAF actif.

11. Cross-Site Scripting (XSS)

- **Définition:** injection de script malveillant dans une page web.
- **Règles:** échapper les sorties ; CSP ; revue de code + tests.

12. DDoS (déni de service distribué)

- **Définition:** inonder un service pour le rendre indisponible.
- **Règles:** anti-DDoS/CDN ; plans de continuité ; monitoring et scaling.

13. Rogue Wi-Fi / Evil-Twin / MITM

- **Définition:** point d'accès pirate pour intercepter le trafic.
- **Règles:** utiliser VPN ; éviter Wi-Fi public ; 802.1X sur Wi-Fi pro.

14. USB piégée (USB drop)

- **Définition:** clé laissée pour être branchée et infecter un poste.
- **Règles:** ne pas brancher clé inconnue ; bloquer autorun ; contrôler accès USB.

15. Câble USB / borne pirate (juice-jacking)

- **Définition:** câble/borne qui vole des données via le port USB.
- **Règles:** utiliser son câble ; mode "charge only" ; éviter bornes publiques.

16. QR-code frauduleux

- **Définition:** QR qui redirige vers un site malveillant.
- **Règles:** vérifier la source ; taper l'URL à la main ; utiliser lecteur sécurisé.

17. SIM swap (détournement de numéro)

- **Définition:** prise de contrôle du numéro pour recevoir codes SMS.
- **Règles:** préférer apps MFA ; activer verrou opérateur ; alerter en cas de perte de service.

18. DNS spoofing / hijack

- **Définition:** falsification de résolutions DNS pour rediriger vers des sites malveillants.
- **Règles:** utiliser DNSSEC ; filtrage DNS/Proxy ; surveiller anomalies DNS.

19. Mauvaise configuration cloud / données exposées

- **Définition:** services cloud mal configurés exposant des données.
- **Règles:** audits réguliers ; principe du plus bas privilège IAM ; chiffrement et logs.

20. Botnet / IoT compromis

- **Définition:** objets connectés piratés utilisés pour attaques en masse.
- **Règles:** changer mots de passe par défaut ; segmenter IoT ; appliquer mises à jour.